



File No.: EXP202213331

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On April 10, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against VODAFONE SERVICIOS, S.L.U. (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No.: EXP202213331

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions carried out by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: Mr. A.A.A., on behalf of Mr. B.B.B. (hereinafter, the claimant), filed a complaint with the Spanish Agency for Data Protection on November 4, 2022. The complaint is directed against VODAFONE SERVICIOS, S.L.U. with NIF B87539284 (hereinafter, Vodafone). The reasons for the complaint are as follows:

The claimant states that a duplicate of his SIM card has been made with the purpose of impersonating his identity to gain access to his banking entity and thus make charges, cash withdrawals, and purchases charged to his account.

He provides a complaint made to the telecommunications operator in question, a complaint directed to his banking entity, a police report, and a request for arbitration before the Arbitration Board of Consumption of Granada.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to Vodafone, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on December 28, 2022, as evidenced by the acknowledgment of receipt in the file.

On February 8, 2023, this Agency received a response indicating: "After conducting the appropriate investigations regarding what occurred and having confirmed that my represented party has carried out all the pertinent actions prior to the notification of this request for information, a letter has been sent to the claimant informing him of the actions taken by Vodafone to resolve the incident, which is currently resolved.

In particular, it is informed that the actions reported by the claimant have been classified as fraudulent, specifically the duplicate of his SIM card. Furthermore, the claimant is informed that what happened was declared fraudulent by Vodafone's Fraud Department, and additional security measures have been implemented on the claimant's customer account to prevent similar incidents in the future.

The complaint originates from the fact that the claimant, a user of a mobile phone line ***PHONE.1, reports having been a victim of malicious actions by an unknown third party through which duplicate SIM cards were requested without his consent to ultimately carry out unauthorized charges on his bank account.

After analyzing the complaint and investigating what happened, Vodafone has been able to verify that various fraudulent actions were carried out on the mobile phone line belonging to the claimant.

A duplicate SIM was processed on July 19, 2022, managed by phone, through a collaborator of this entity in the customer service management.

Additionally, other duplicate SIMs were requested on July 20, 2022, which are recorded as canceled.

Finally, the claimant made a further duplicate SIM on July 21, 2022, as he himself states in his complaint.

This party wishes to point out that the effective management of a duplicate SIM card is subject to the overcoming of the security policies that Vodafone has implemented to prevent fraudulent practices on the personal data of its customers.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/13

In this regard, and given that the management in question was processed under the aforementioned security policy, my client understood at all times that these were lawful, real, and truthful actions.

In light of the events that occurred, once the claimant became aware of the reported facts on September 6, 2022, they contacted my client indicating that the previous actions had allegedly been carried out without their consent, marking the first moment that Vodafone became aware of the facts subject to the claim.

In this sense, my client proceeded to conduct the appropriate investigations and actions to resolve the incident that occurred.

Therefore, on the same day that the facts subject to the claim were acknowledged, after verifying that Vodafone was dealing with actions that, despite appearing to be truthful, were fraudulent in nature, it proceeded to deactivate the fraudulent SIM card to rectify this incident, activating additional security measures on the claimant's customer account to prevent any further harm to the claimant.

Finally, the claimant's mobile phone line was terminated on November 6, 2022.

Thus, it does not seem possible for there to be a correlation between the events that occurred in relation to my client and what happened with the banking entity of which the claimant is a customer. In this regard, the banking transactions alleged in their claim do not originate from, nor have they been caused by invoices for services contracted with Vodafone, but rather are due to accesses made through the account of their banking entity.

Therefore, Vodafone cannot be held responsible for accesses and banking transactions that may have been carried out fraudulently.

THIRD: In accordance with Article 65 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (LOPDGDD), when a claim is presented to the Spanish Agency for the Protection of Data (hereinafter, AEPD), it must evaluate its admissibility for processing, notifying the claimant of the decision regarding the admission or inadmissibility for processing within three months from the date the claim was received by this Agency.

If, after this period, such notification does not occur, it will be understood that the processing of the claim continues in accordance with the provisions of Title VIII of the Law. This provision also applies to the procedures that the AEPD must process in exercising the powers conferred upon it by other laws. In this case, taking into account the above and that the claim was presented to this Agency on November 4, 2022, it is communicated that your claim has been admitted for processing on February 4, 2023, having passed three months since it was received by the AEPD.

FOURTH: According to the report obtained from the AXESOR tool, the entity VODAFONE SERVICIOS, S.L.U. is a large company established in 2016, with a business volume of 81,314,000 euros in 2022.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for the Protection of Data is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for the Protection of Data shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not

contradict them, subsidiarily by the general rules on administrative procedures.”

II

Obligation Breached

Beforehand, it is necessary to point out that Article 4.1 of the GDPR defines: “personal data” as “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.”

In this regard, it is important to clarify that within the mobile terminal, the SIM card is inserted. It is a smart card, in a physical format and of small dimensions, which contains a chip that stores the service key of the subscriber used to identify themselves to the network, that is, the mobile phone line number of the customer MSISDN (Mobile Station Integrated Services Digital Network), as well as the personal identification number of the subscriber IMSI (International Mobile Subscriber Identity), but it can also provide other types of data such as information about the telephone directory or call and message logs.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/13

On the other hand, the issuance of a duplicate SIM card involves the processing of the personal data of its holder, as any person whose identity can be determined, directly or indirectly, particularly by means of an identifier (Article 4.1 of the GDPR), is considered an identifiable natural person.

Therefore, the SIM card identifies a phone number, and this number, in turn, identifies its holder. In this regard, the Judgment of the CJEU in Case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971 states: "The concept of 'personal data' used in Article 3(1) of Directive 95/46 includes, according to the definition in Article 2(a) of that Directive, 'any information relating to an identified or identifiable natural person.' This concept undoubtedly includes a person's name along with their phone number or other information relating to their working conditions or hobbies."

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally identifies the subscriber on the network are personal data, and their processing must be subject to data protection regulations.

The respondent is accused of committing an infringement by violating Article 6 of the GDPR, "Lawfulness of processing," which states in paragraph 1 the circumstances under which the processing of third-party data is considered lawful:

“1. Processing shall be lawful only if at least one of the following applies:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) processing is necessary to protect the vital interests of the data subject or of another natural person;
- e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child. The provisions of point f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks.”

III

Classification and Qualification of the Infringement

C/ Jorge Juan, 6

The infringement is classified under Article 83.5 of the GDPR, which considers the following as such:
“5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) The basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9.”

The LOPDGD, for the purposes of the statute of limitations for the infringement, classifies it in Article 72.1 as a very serious infringement, with a limitation period of three years in this case, “b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679 being met.”

In this case, it has been established that Vodafone provided a duplicate SIM card to a third party without their consent and without verifying the identity of that third party, who accessed information contained in the mobile phone, such as banking data, passwords, email address, and other personal data associated with the device. Thus, the respondent did not verify the identity of the person who requested the duplicate SIM card and did not take the necessary precautions to prevent these events from occurring.

Based on the above, the diligence employed by the respondent to identify the person who requested a duplicate SIM card is called into question.

According to the respondent, "Vodafone has been able to verify that various fraudulent actions were carried out on the mobile phone line belonging to the claimant.

A duplicate SIM was processed on July 19, 2022, managed by phone through a collaborator of this entity in customer service management.

Additionally, other duplicate SIMs were requested on July 20, 2022, which are recorded as canceled." It should be noted that SIM Swapping is a fraud that allows identity theft by hijacking the phone number through obtaining a duplicate SIM card.

In any case, the operator must be able to demonstrate that for this specific case, they followed the verification protocols implemented when requesting a duplicate SIM card.

The result was that the respondent issued the SIM card to a third party who was not the holder of the line.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

In light of the above, the responding party fails to demonstrate that the procedure was followed.

In the explanation provided by the responding party, there is no indication of what the specific cause may have been that led to the issuance of the duplicate, beyond some generic explanations regarding a possible "human error," non-compliance by Vodafone's collaborators, or even "organized criminal activity." In any case, the responding party has not been able to prove that the procedure implemented by itself was followed in this instance, as, had it been done, the denial of the duplicate SIM card should have occurred.

Based on the aforementioned, in the case analyzed, the diligence employed by the responding party to identify the person who requested a duplicate of the SIM card is called into question.

In accordance with the evidence available at this procedural moment and without prejudice to the outcome of the instruction of the procedure, it is estimated that the conduct of the responding party could violate Article 6.1 of the GDPR and could constitute the infringement typified in Article 83.5.a) of the aforementioned Regulation 2016/679.

In this regard, Recital 40 of the GDPR states:

“(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on some other legitimate basis laid down by law, whether in this Regulation or by virtue of other Union or Member State law to which this Regulation relates, including the necessity of complying with a legal obligation to which the controller is subject or the necessity of performing a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract.”

IV

Proposal for Sanction

The determination of the sanction to be imposed in this case requires observing the provisions of Articles 83.1 and 2 of the GDPR, which respectively state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines pursuant to this Article for the infringements of this Regulation referred to in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

“2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding to impose an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage suffered by data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringements committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures referred to in Article 58, paragraph 2, have previously been ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factors applicable to the circumstances of the case, such as the financial benefits gained or losses avoided, directly or indirectly, through the infringement.”

Within this section, the LOPDGDD provides in its Article 76, titled “Sanctions and Corrective Measures”:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/13

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) To have, when not mandatory, a data protection officer.
- h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.

3. It will be possible, additionally or alternatively, to adopt, when appropriate, the remaining corrective measures referred to in Article 83.2 of Regulation (EU) 2016/679.”

In accordance with the transcribed provisions, and without prejudice to what may result from the instruction of the procedure, for the purpose of determining the amount of the fine to be imposed on the entity claimed as responsible for an infringement classified in Article 83.5.a) of the GDPR and 72.1 b) of the LOPDGD, an initial assessment considers the following factors to be concurrent in the present case:

As aggravating factors:

- The evident link between the business activity of the claimed entity and the processing of personal data of clients or third parties (Article 83.2.k of the GDPR in relation to Article 76.2.b of the LOPDGD).

Number of affected parties: The initiation agreement includes the claim made by one claimant.

The Judgment of the National Court of 17/10/2007 (rec. 63/2006), regarding entities whose activity involves continuous processing of client data, indicates that “...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on rigor and exquisite care to comply with the legal provisions in this regard.”

As mitigating factors:

The claimed party proceeded to effectively resolve the incident subject to the claim (art. 83.2 c).

It is appropriate to graduate the sanction to be imposed on Vodafone and set it at the amount of seventy thousand euros for the alleged infringement of Article 6.1) classified in Article 83.5.a) of the aforementioned GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/13

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection.

IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against VODAFONE SERVICIOS, S.L.U. with NIF B87539284 for the alleged infringement of Article 6.1) classified in Article 83.5.a) of the aforementioned GDPR.

SECOND: TO APPOINT Mr. C.C.C. as instructor and Ms. D.D.D. as secretary, indicating that either of them may be recused, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the claim filed by the claimant and its documentation, the documents obtained and generated by the General Subdirectorato of Data Inspection.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be for the infringement of Article 6.1 of the GDPR, classified in Article 83.5 a) of the GDPR, the sanction that would correspond would be a fine in the amount of 70,000 euros (seventy thousand euros) without prejudice to what may result from the instruction.

FIFTH: TO NOTIFY this agreement to VODAFONE SERVICIOS, S.L.U. with NIF B87539284 granting a hearing period of ten working days for them to submit allegations and present the evidence they deem appropriate. In their written allegations, they must provide their NIF and the procedure number that appears in the heading of this document.

If no allegations are made to this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, in the event that the sanction to be imposed is a fine, they may acknowledge their responsibility within the period granted for the formulation of allegations to this initiation agreement; which will entail a reduction of 20% of the sanction to be imposed in this procedure, equivalent in this case to fourteen thousand euros (14,000 €).

With the application of this reduction, the amount of the sanction would be established at fifty-six thousand euros (56,000 €), resolving the procedure with the imposition of this sanction, without prejudice to the imposition of the corrective measures that may correspond.

Likewise, they may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, in accordance with the provisions of Article 85.2 LPACAP, which will entail a reduction of 20% of its amount, equivalent in this case to fourteen thousand euros (14,000 €), for the alleged infringement. With the application of this reduction, the amount of the sanction would be established at fifty-six thousand euros (56,000 €) and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/13

its payment will imply the termination of the procedure, without prejudice to the imposition of the corrective measures that may correspond, if applicable.

The reduction for the voluntary payment of the sanction is cumulative with the one that corresponds to be applied for the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations regarding the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction will be established at forty-two thousand euros (€42,000).

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction.

In the event that you choose to proceed with the voluntary payment of either of the amounts indicated above, €56,000 or €42,000, you must make it effective by depositing it into account no. ES00 0000 0000 0000 0000 opened in the name of the Spanish Agency for Data Protection at CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering.

You must also send the proof of payment to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of nine months from the date of the initiation agreement or, where applicable, from the draft initiation agreement. After this period, it will expire, and consequently, the file of actions will take place; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On May 12, 2023, the respondent has proceeded to pay the sanction in the amount of €56,000 making use of one of the two reductions provided for in the previously transcribed Initiation

Agreement. Therefore, the acknowledgment of responsibility has not been evidenced.

THIRD: The payment made entails the waiver of any action or administrative appeal against the sanction, in relation to the facts referred to in the Initiation Agreement.

LEGAL GROUNDS

I

Competence

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/13

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), under the heading "Termination in sanctioning procedures" provides the following:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the corresponding sanction.

2. When the sanction is solely pecuniary or when a pecuniary sanction can be imposed along with a non-pecuniary sanction but the latter has been justified as inappropriate, the voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely pecuniary, the competent body to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which will be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure and their effectiveness will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation."

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202213331, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO NOTIFY this resolution to VODAFONE SERVICIOS, S.L.U.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/13

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the

interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

937-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es